Kestrel Shield Fraud Rules

Rule set v14. Restricted: Payments Engineering and Security only.

Document control	
Rule set	v14, live since 13 July 2026 (v14.2 since 7 September 2026)
Owners	Lena Fischer (Security Engineer), Omar Haddad (Payments Engineer, rule engineering)
Product sign-off	Julia Novak (Payments Product Manager)
Review cycle	Monthly fraud review, first Thursday of the month
Sharing	Do not copy, forward or summarise these rules outside Payments Engineering and Security. Support, Sales and merchants never see rule names, thresholds or scores.

1. How Kestrel Shield decides

Every card authorisation and every payout passes through the risk engine before it reaches the acquirer or the payment scheme. The engine scores each event from 0 to 100 using the model `shield-gbm-2026-06`, then applies the rules below in order. The first rule that blocks wins. If no rule blocks, the score decides:

Score	Action	Customer sees
0 to 59	Allow	Normal payment
60 to 84	Step up: force 3-D Secure challenge	Bank's authentication check
85 to 100	Block	KP-4040

v14 followed the card-testing attack on Checkout in April 2026, which cost about £180,000 in chargeback losses before an emergency rule in v13.4 stopped it. v14 made that rule permanent as FR-110 and moved the score bands down: in v13 the step-up band started at 65 and the block band at 90. Moving them down cut fraud losses in the July trial by 18%, for a rise in 3-D Secure challenges from 9.1% to 11.4% of card payments.

A blocked payment returns KP-4040 to the merchant. A blocked payout returns the code shown in the rule; a held payout shows status `held` with a reason.

2. Card payment rules

Rule	Name	Condition	Action
FR-101	Device velocity	More than 5 card attempts from one device fingerprint in 10 minutes, across any merchants	Block for 1 hour (KP-4040)
FR-102	Card velocity	More than 8 attempts on one card number in 1 hour	Block the card for 24 hours (KP-4040)
FR-104	CVC guessing	3 failed CVC checks in a row on one card within 30 minutes	Block the card for 24 hours (KP-4040)
FR-110	Card testing	More than 20 authorisations under £2 on one merchant in 5 minutes	Block small payments on that merchant for 2 hours and page Payments on-call
FR-115	Country mismatch	Card issuing country, IP country and billing country all differ, and the amount is over £250	Step up to 3-D Secure
FR-120	New merchant, large ticket	Merchant live for under 30 days and a single payment over £2,000	Hold for manual review, 4 business hours target
FR-122	New merchant, volume spike	Merchant live for under 90 days and daily volume over 3 times its 7-day average and over £10,000	Delay settlement by 2 days and alert Risk Operations
FR-130	Known bad BIN	BIN on the shared blocklist `bin_block_v14`	Block (KP-4040)
FR-135	Refund abuse	Refunds over 40% of the merchant's 7-day volume, with at least £5,000 refunded	Pause refunds and alert Risk Operations

3. Payout rules

Rule	Name	Condition	Action
FR-201	New beneficiary, large payout	Payout over £10,000 to a beneficiary created less than 24 hours ago	Hold for review. The payout shows status `held` with reason `risk_review`
FR-203	Confirmation of Payee close match, large payout	Confirmation of Payee result is a close match (KP-5004) and the amount is over £1,000	The merchant's confirmation needs a second approver on their account, in the Dashboard only; API confirmation is refused
FR-205	Payroll spike	Payroll batch total over 2.5 times the average of the last 3 payroll batches	Hold the batch and ask the merchant to confirm in the Dashboard
FR-210	Out of hours, new device	Payout approved from a device never seen on the account, between 23:00 and 05:00 UK time, over £5,000	Hold until the account owner confirms by app
FR-215	Mule pattern	More than 10 new beneficiaries added in 24 hours, each paid under £1,000	Hold all payouts on the account and alert Risk Operations

4. Allowlists and overrides

- Risk Operations can allowlist a merchant against FR-110 and FR-122 for up to 14 days. The allowlist entry must have a ticket number and an expiry.
- Nobody can allowlist against FR-130, FR-203 or FR-215.
- An override of a single blocked payment needs two people: one from Risk Operations and one from Payments Engineering. Overrides are logged in `shield_overrides` and reviewed at the monthly fraud review.
- Merchant requests to lift a block come through Customer Success. Customer Success must not tell the merchant which rule fired.

5. Changes in v14.2 (7 September 2026)

- FR-205 threshold raised from 2 times to 2.5 times the average. In August, 63% of FR-205 holds were legitimate bonus runs, most of them from hospitality merchants paying summer bonuses.
- FR-110 now pages Payments on-call directly instead of opening a ticket. During the card-testing attack on 29 August 2026, ticket-only alerts left a 26 minute gap before anyone looked.
- Added FR-135 after three refund-abuse cases in Q2 2026 cost £41,300 in total.

6. Monitoring

Signal	Alert threshold	Who is paged
Block rate across all card payments	Over 2.0% for 15 minutes	Payments on-call
Step-up rate	Over 15% for 30 minutes	Payments on-call
Manual review queue (FR-120, FR-201)	Over 150 items, or oldest item over 4 hours	Risk Operations lead
Risk engine p99 latency	Over 120 ms for 5 minutes	Platform on-call

If the risk engine is down, card payments fail open for scores only: the rules FR-101, FR-102, FR-104 and FR-130 still run from the local cache in `payments-core`, and every other payment is allowed with a forced 3-D Secure challenge. Payouts fail closed: nothing is sent until the engine is back.

7. Proposing a rule change

1. Open a ticket in the RISK project with the rule, the evidence and the expected effect on block and step-up rates.
2. Run the change in shadow mode for at least 7 days. Shadow results go to the `shield-shadow` dashboard.
3. Lena Fischer and Omar Haddad both approve the change. Julia Novak signs off any change that raises the step-up rate by more than 1 percentage point.
4. Ship it behind the `shield.rules.v14` flag, 10% of traffic first, then 100% after 48 hours without regressions.